

SMARTMETER CO.

Incident Report

Prepared by: Azeez O. Yusuff
December 31, 2023

Executive Summary

SmartMeter Co. experienced a significant cybersecurity incident from a phishing attack resulted in the compromise of several user credentials and further compromise of sensitive and confidential data stored on SmartMeter Co's servers. The incident was characterized by a phishing attack and suspicious activities, including the access to unauthorized user accounts, modifications to system files, and the execution of potentially malicious processes, which resulted in the compromise of several user credentials and further compromise of sensitive and confidential data stored on SmartMeter Co's servers.

The attacker was able to gain access and spread throughout the network due to unprotected email server traffic, outdated server, weak authentication, poor password practices and lack of training and information to help employees detect fake page or phishing email allowing them to manipulate system configurations and compromise and access files and the IIoT platform.

Incident Details

SmartMeter Co. experienced a significant cyber security incident from a phishing attack resulted in the compromise of several user credentials and further compromise of sensitive and confidential data stored on SmartMeter Co's servers.

- **Date and Time**: December, 2023
- **Incident Severity**: High

Root Cause Analysis

1. High Level Observations from Logs:

Observation 1 –

Email Server Logs:

The email server logs indicate suspicious behavior resulting from phishing emails targeted at employees of SmartMeter Co. and requesting for verification of credentials through a provided link. The phishing emails spreads across a few more employees as the first recipients forwarded email to HR Manager who was preparing Christmas bonuses and Vinod, a member of the IIoT engineering team. These activities suggest a potential compromise with an attempt to manipulate system configurations and access files and the IIoT platform.

Firewall Logs:

Firewall logs show that critical files containing company information, top secrets and human resources information regarding information such as IIoT product source code, employees' information and Christmas bonuses are successfully read, copied and updated. Although attempts to access a few of the company's information, employees and top secrets failed and deleted as well.

Observation 2 –

SQL Server Logs:

Logs on SQL Server reveal suspicious behavior, including odd updates in the code, wield files and emails from the server, unauthorized user creations, and the execution of suspicious applications. Specifically, excel files being copied successfully raises concerns about potential unauthorized activities.

2. High Level Interview Insights:

Insight 1 –

Interview with CEO (Jack):

Jack stressed that the urgency of the request and the familiar look of the page convinced him that the link in the phishing email was legitimate. There was lack of information to help Jack with detecting a fake page or phishing email at the time of attack.

Insight 2 –

Interview with IIoT Engineer (John):

John stressed during the interview that, since he is a very important member of the engineering team, he cannot afford any delays accessing systems, did not hesitate and entered his credentials all the time for emails. He also stressed that he noticed some odd updates from Jack in the code and attempt to access the IioT from home.

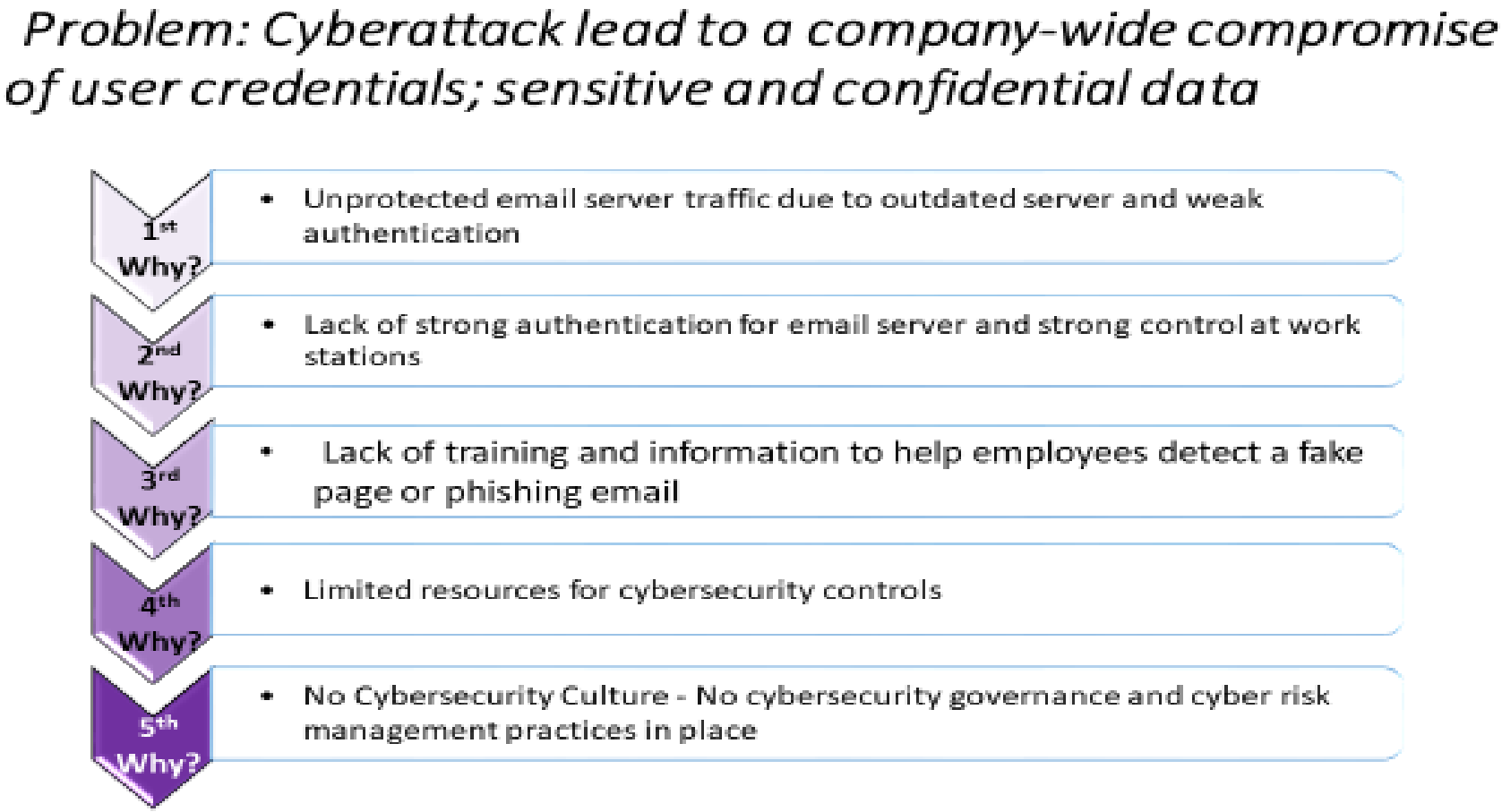
Insight 3 –

Interview with HR Manager (Chillantra):

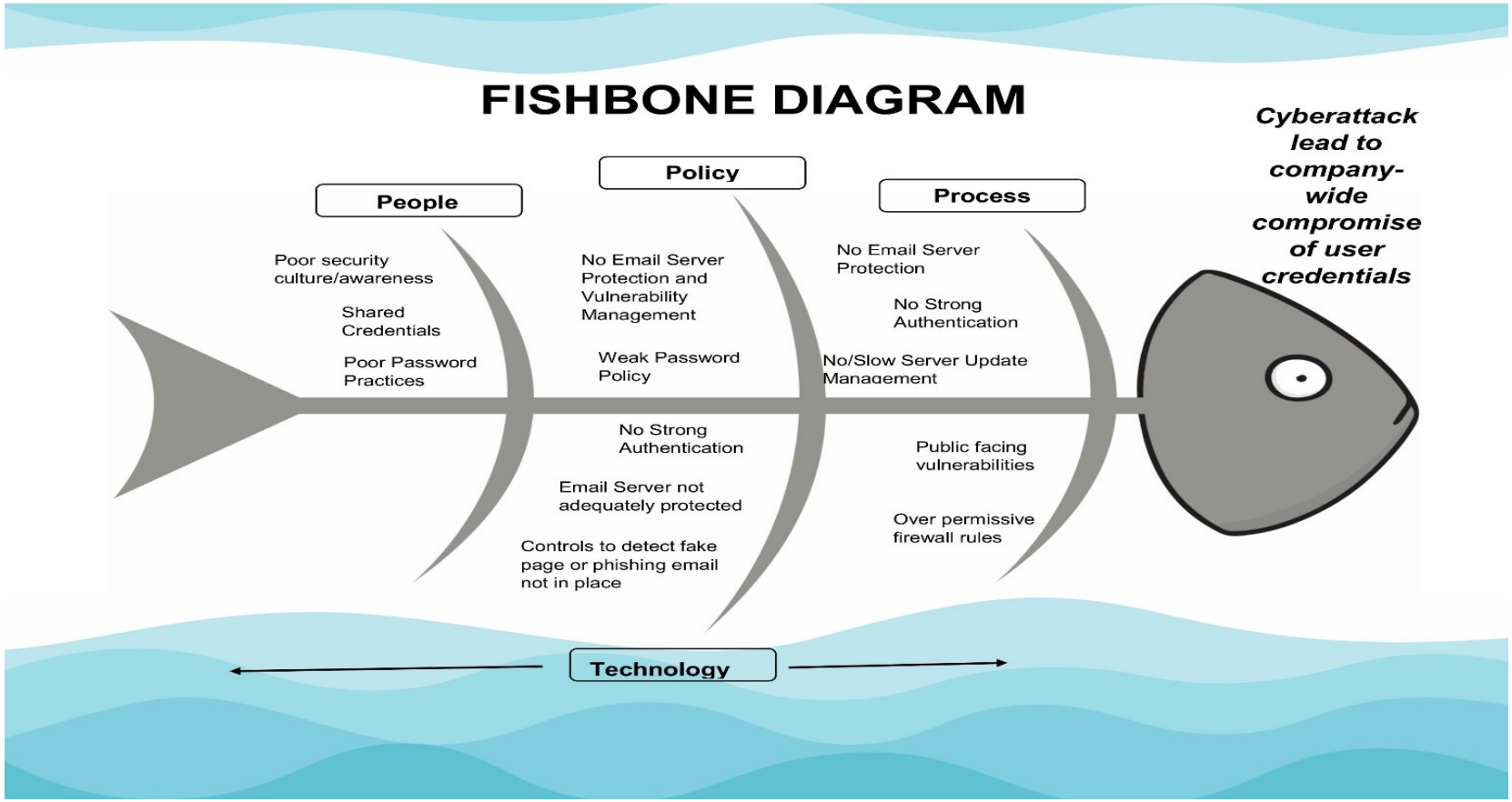
Although Chillantra noticed that the link looked odd with a lot of spelling mistakes, wrong URL and fuzzy graphics, she clicked on the link and followed instructions from John to avoid losing access to accounts and continue to process employee Christmas bonuses, since she can trust any link from John. Notably, she changed her password shortly after for safety and to prevent John from accessing the employee bonuses file and changing his bonus.

3. Root Cause Analysis Screenshot

a) 5 Whys Analysis (for problem statement) screenshot



b) Fishbone Analysis Screenshot



4. Attack Vector: Email, an attacker launched a phishing attack resulted in the compromise of several user credentials and further compromise of sensitive and confidential data stored on SmartMeter Co's servers.

5. State the intrusion point: The attacker was able to gain access and spread throughout the network due to unprotected email server traffic, outdated server, weak authentication, poor password practices and lack of training and information to help employees detect fake page or phishing email allowing them to manipulate system configurations and compromise and access files and the IIoT platform.

Failed Controls

Failed control 1 -

Failed Control: AT-2 - Security Awareness Training

Reason: Lack of training and awareness to help employees detect fake page or phishing email, potential deviations and the presence of a new user account on a workstation suggest a potential failure in security awareness training.

System and Information Integrity (SI) Family:

Failed control 2 -

Failed Control: AC-2 - Account Management

Reason: Shared credentials among users and the use of a shared Administrator password across workstations and servers indicate weaknesses in account management practices, potentially leading to unauthorized access.

Configuration Management (CM) Family:

Prioritized Recommendations Based on Overall Risk

		Selection Criteria Weighting				
Priority Rank		10	5	3	10	
NIST SP800-53 Control Family	Control Utilization	Criteria				Priority Score
		Impact to organization	Time sensitivity	Risk	Affordability	
Maintenance (MA)	Identification and patching of vulnerabilities in the organization	9	9	9	9	252
Maintenance (MA)	Implement Automatic Blocking of fake page and phishing email	3	3	9	9	162

Criteria Score
0 = Minimal/None
1 = Low

System And Communications Protection (SC)	Enhance Email Protection and Firewall Rules	9	9	9	9	**252**	3 = Moderate
System And Communications Protection (SC)	Establish Strong Authentication	3	1	1	1	**48**	9 = Important
Audit and Accountability (AU)	Establish controls to detect fake page or phishing email	3	3	3	3	**84**	

Conclusion

It is recommended that email protection and firewall rules are enhanced and any patch vulnerabilities are identified and updated immediately, as this poses a high impact and risk to the organization, is time sensitive as delaying updates to email protection and firewall rules and patches can further compound the organization's vulnerability to another attack and there will be no cost to updating this as it should already be included as part of any existing software and hardware implementations.